UNIVERSITY OF LONDON

BSc EXAMINATION 2023

For Internal Students of
Royal Holloway

DO NOT TURN OVER UNTIL TOLD TO BEGIN

IY3612: CYBER SECURITY

IY3612R: CYBER SECURITY – PAPER FOR FIRST SITS/RESIT CANDIDATES

Time Allowed: **TWO** hours

Attempt **three** questions.
No credit will be given for attempting any further questions.

Important Copyright Notice
This exam paper has been made available in electronic form
strictly for the educational benefit of current Royal Holloway students
on the course of study in question.
No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.
© Royal Holloway University of London 2023

Question 1 Adversary Modelling

(a) A security analyst wishes to model attack pathways an adversary may use to compromise a back end database system from outside the target organisation.

(i) Construct three distinct attack scenarios of which at least two must share a common element, and briefly describe the elements contributing to a successful compromise for each scenario (path). [8]

(ii) Convert the scenarios in the answer for question 1(a)(i) above into an **Attack Tree** showing the relation between the attack paths. [6]

(b) Convert the attack tree from question 1(a) into an **Attack Countermeasure Tree**.

Demonstrate how the use of success probabilities of certain mitigation measures can be used to prioritise mitigation measures if it can be assumed that all three attack paths are otherwise equally likely. [11]

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

Question 2 Cyber Conflict

(a) Successful cyber attacks on large organisations can result in very large losses. Many companies have sought to manage residual risks of such attacks by taking out cyber attack insurance policies.

(i) How can an insurance company set appropriate price levels for cyber insurance that will ensure it will not lose money on the aggregate of a larger number of policies over several years?

Give a reasoned answer. [7]

(ii) Conflicts between nation states may result in collateral damage in the form of cyber attacks. Under which circumstances can an insurance company deny paying out for a cyber attack insurance policy after an event caused by such collateral damage? Give a brief, reasoned answer. [5]

(b) Many nation states are continuously engaging in intelligence operations, particularly in the cyber domain.

(i) How can publishing a national cyber security strategy help to prevent such intelligence gathering be transformed into offensive cyber operations? [7]

(ii) The United Kingdom acknowledges maintaining offensive cyber capabilities. Can this information be used against the interests of the United Kingdom during a cyber security incident in a nation state not necessarily on friendly terms with the UK? Give a brief, reasoned answer. [6]

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

Question 3 ICS Security

(a) Natural gas pipelines operate at high pressure (6–8 MPa, approx. 1000 psi) carrying highly flammable material. To transport the gas over long distances whilst maintaining constant pressure, compressor stations are placed along the length of pipelines.

These compressor stations must monitor the flow and composition of the gas, and then use one or more turbines (typically gas-powered turbomachines) together with so-called scrubbers to remove impurities and condensates and cooling systems to maintain a steady flow of gas.

(i) Assume that the operator of the compressor station has learned, that an adversary has been able to manipulate flow sensors in a compressor station. Should the operator maintain operation, and if so under which conditions? Give a brief, reasoned answer. [7]

(ii) Compressor stations also contain separate, automatic emergency shutdown (ESD) devices that monitor for leaks, pipeline breaks, or fire and will activate a so-called "emergency blowdown", venting gas rapidly from compressor and pipeline segments.

Which design considerations should be taken when designing the sensor network for the ESD system to be robust to cyber attacks? Give a brief, reasoned answer. [5]

(b) Pipelines such as natural gas pipelines in question 3(a) must be cleaned and inspected regularly. The inspection is performed by "pigs" travelling down lengths of pipeline, with "smart pigs" containing autonomous PLC and sensors.

(i) How could a pipeline operator protect itself against a supply chain attack in which the sensors or measurement logic of smart pigs is manipulated? Give a brief, reasoned answer. [7]

(ii) Consider the prevention and detection mechanisms described in the answer to question 3(b)(i). Can the adversary anticipate and bypass these to still succeed and if so, how? Give a brief, reasoned answer. [6]

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

Question 4 Security in Control Systems

(a) A control system is operating using a *feed forward* control law in which a model inside the controller is used to anticipate the system's behaviour.

(i) An adversary is able to cause messages to an actuator to be *suppressed* intermittently. How will the feed-forward controller respond? Give a brief, reasoned answer. [7]

(ii) How would the behaviour of a system with a *feedback controller* be different under the same attack pattern as in question 4(a)(i)? Give a brief, reasoned answer. [6]

(b) In a distributed control system, real-time control loops are executed by specialised programmable logic controllers (PLC) or remote terminal units (RTU). These are monitored and also programmed by SCADA systems running commodity operating systems.

Which *ICS-specific* security measures must be taken on the SCADA system to ensure that the *integrity* of the code running on the PLC/RTU is not put into jeopardy? Give a reasoned answer. [12]

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

Question 5 Dependency Models

(a) A dependency model allows the identification of vertices or edges in networks which would cause large-scale disruption if these were to fail or be attacked successfully.

Review the simplified diagram of the UK national gas transmission system (NTS) in figure 1.

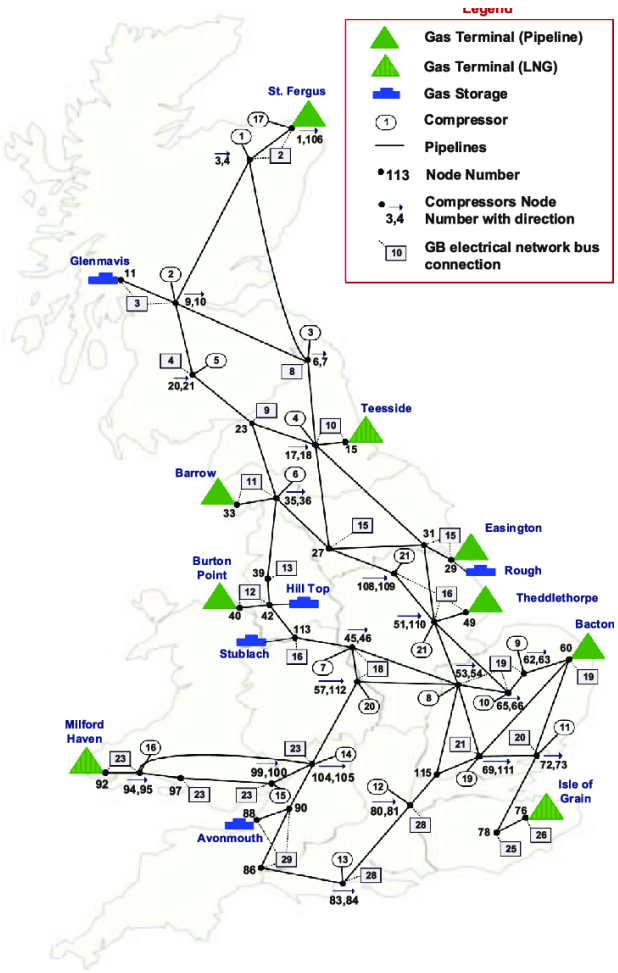

Figure 1: Simplified UK National Transmission System for Natural Gas (Source: National Grid)

Assume that only connectivity information is available.

If an adversary were able to disable only two arbitrary edges (pipelines), would this result in more severe restrictions than if two vertices (pumping

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

stations) were disabled?

Give a reasoned hypothesis and sketch which algorithm(s) you would need to run on the network to validate the hypothesis [12]

(b) The diagram in figure 1 only shows the ordinary direction of flow, but does not include capacity information.

If edge capacity information is available, which algorithms would be required to answer question 5(a) more precisely? Identify under which circumstances the answer to question 5(a) would differ substantially from the case of only considering connectivity. [13]

END

Stephen Wolthusen

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.